

# Project 1: TestFire Login Security Analysis

## Introduction

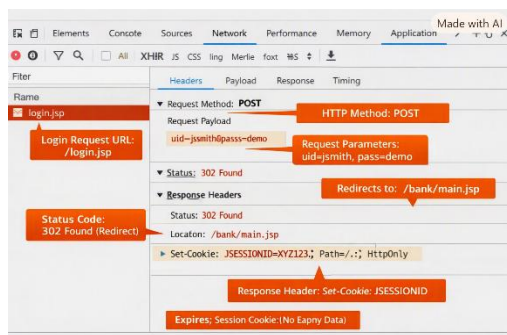
This project analyzes the login process of the TestFire (Altoro Mutual) application using browser developer tools. The objective is to understand authentication, authorization, sessions, cookies, and HTTP communication.

## Tools Used:

- Google Chrome / Mozilla Firefox
- Browser Developer Tools (F12)
- Internet connection

## Login Process Analysis

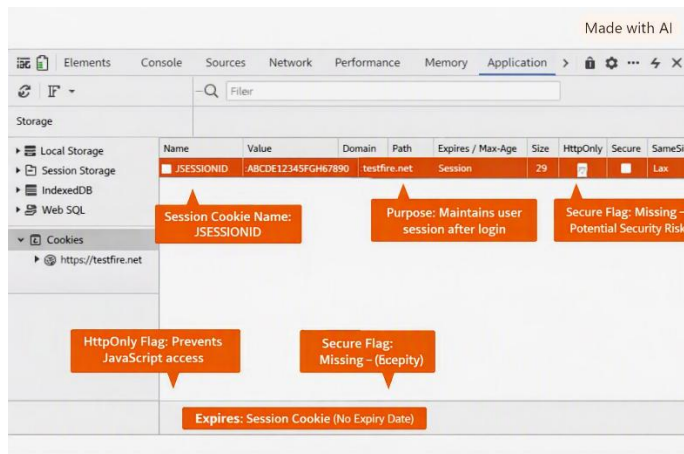
- **Login URL:** https://testfire.net/login.jsp
- **HTTP Method:** POST
- **Request Headers:**
  - Host: testfire.net
  - User-Agent: Mozilla/5.0 ...
  - Content-Type: application/x-www-form-urlencoded
- **Request Parameters:**
  - uid=jsmith
  - pass=demo
- **Response Headers:**
  - Set-Cookie: JSESSIONID=XYZ123; Path=/; HttpOnly
  - Content-Type: text/html; charset=UTF-8
- **HTTP Status Code:** 302 Found (redirect after login)



Network tab showing login request/response

## Cookies & Sessions

- **Session Cookie:** JSESSIONID created after successful login.
- **Purpose:** Maintains user session between client and server.
- **Observation:** Session cookie disappears after logout.



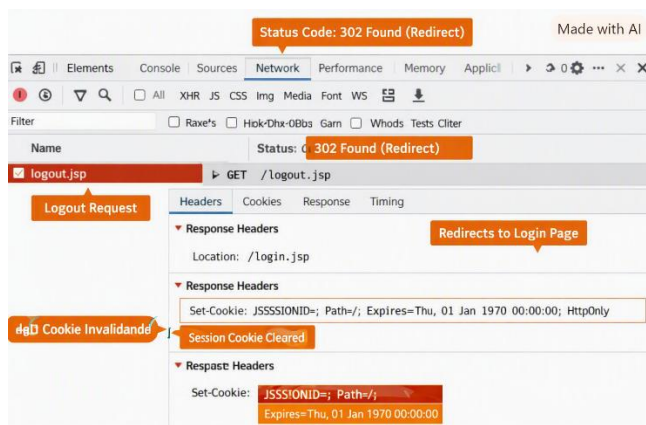
Cookies tab showing JSESSIONID

## Key Concepts

- **Authentication:** Verifying user identity (username/password).
- **Authorization:** Granting access to resources based on role.
- **Session:** Temporary state maintained between client and server.
- **Cookie:** Small piece of data stored in the browser to track sessions.

## Logout Verification

- After clicking **Logout**, the session cookie is invalidated.
- Attempting to access restricted pages requires re-authentication.



*Network tab after logout*

### **Security Observations**

1. **Credentials in Plaintext Parameters:** Username/password visible in request payload.
2. **Session Management Risk:** If cookies are not invalidated properly, session hijacking is possible.
3. **Weak Authentication:** Demo credentials are static and predictable.
4. *(Optional)* Lack of HTTPS enforcement exposes credentials to interception.

### **Conclusion**

This exercise demonstrates how login flows rely on authentication, authorization, cookies, and sessions. It also highlights common security issues in demo applications.